

Migrant Work TW - Laporan Harian (Optimasi Keamanan Backend & Perbaikan Mobile)

Tanggal: 29 Juni 2026

Cakupan: Backend API (Laravel) & Mobile App (Flutter)

Ringkasan Eksekutif

Dokumen ini merangkum seluruh pekerjaan, perbaikan logika, bug fix pada aplikasi mobile, serta penguatan keamanan tingkat lanjut yang dilakukan pada platform Migrant Work TW hari ini.

Optimasi Keamanan yang Diimplementasikan

1. Atomic Database Transactions (Integritas Data)

- **Kondisi:** Sistem sudah diimplementasikan dengan `DB::beginTransaction()`, `DB::commit()`, dan `DB::rollBack()` pada fungsi-fungsi kritikal (seperti pembuatan *job application*, pendaftaran akun, dan *job posting*).
- **Benefit Keamanan:** Hal ini memastikan tidak ada kondisi status sebagian (*partial data state*) jika terjadi kegagalan server di tengah proses (menghindari ancaman manipulasi *race condition* atau data korup).

2. Pemisahan Rate Limiting yang Cerdas (Mitigasi DDoS)

- **Sebelumnya:** Batas `throttle:5,1` (5 *request* per menit) diterapkan pada keseluruhan grup `/api/auth`. Hal ini terlalu membatasi trafik otentik yang sah, seperti memperbarui profil, dan tidak cukup presisi untuk menangkal *botnet* di *endpoint* publik.
- **Sesudahnya:** Batas ketat `throttle:5,1` kini difokuskan hanya pada *endpoint* publik yang berisiko tinggi (`/login`, `/register`, `/forgot-password`, `/send-email-otp`). *Endpoint* yang sudah terautentikasi kini menggunakan batas API standar (default 60 *request* per menit), sehingga tidak mengganggu aktivitas pengguna sah.

3. Account Lockout Berbasis Email (Proteksi Brute Force)

- **Masalah:** Pembatasan berdasarkan alamat IP tidak cukup karena peretas dapat menggunakan VPN atau *botnet* untuk merotasi IP dan meretas satu akun secara masif.
- **Solusi:** Diimplementasikan fitur `RateLimiter` dari Laravel langsung di dalam `AuthController::login`. Sistem kini melacak kegagalan login berdasarkan **alamat email target**. Jika email gagal login 5 kali, akun tersebut dikunci sementara selama 15 menit, melumpuhkan serangan *brute-force*.

4. HTTP Security Headers (Anti-Clickjacking & MIME Sniffing)

- **Solusi:** Dibuat dan diregistrasikan `middleware global SecurityHeaders` pada `bootstrap/app.php`.
- **Headers yang Disuntikkan:**
 - `X-Frame-Options: DENY` (Mencegah aplikasi dimuat di dalam *iframe* berbahaya).
 - `X-XSS-Protection: 1; mode=block` (Memaksa browser untuk memblokir refleksi XSS).
 - `X-Content-Type-Options: nosniff` (Mencegah browser salah menafsirkan file sebagai *skrip/eksekutabel*).
 - `Strict-Transport-Security (HSTS)` - Memaksa penggunaan koneksi HTTPS).

5. Konfigurasi CORS yang Diperketat

- **Sebelumnya:** File `config/cors.php` mengizinkan *request* lintas-asal dari `['*']` (semua domain).
- **Sesudahnya:** Dimodifikasi untuk membaca nilai dari variabel `environment` `CORS_ALLOWED_ORIGINS`. Ini memungkinkan lingkungan *production* untuk memasukkan daftar putih (*whitelist*) secara ketat hanya pada domain resmi dan aplikasi seluler, mencegah domain asing meminta data dari API.

6. Sanitasi Input (Proteksi Cross-Site Scripting / XSS)

- **Masalah:** Employer dapat memasukkan raw HTML atau payload JavaScript berbahaya ke kolom rich-text (Description, Duties, Requirements, Benefits).
- **Solusi:** Menambahkan `strip_tags()` secara otomatis pada `JobController::store` dan `JobController::update`. Semua tag HTML berbahaya akan dibersihkan sebelum masuk ke dalam database.

Perbaikan Logika Aplikasi & Bug Fix Mobile

6. Restriksi Pekerja Tipe "Not Sure"

- **Masalah:** Sistem sebelumnya tidak mengecek jika pekerja memilih tipe *Not Sure* saat melamar pekerjaan.
- **Solusi:** Memodifikasi `JobApplicationController@apply` di backend. Pekerja dengan tipe `not_sure` kini akan mendapatkan respon `403 Forbidden` dan dicegah untuk melamar pekerjaan secara sistem sampai tipe pekerjaanya terverifikasi secara sah.

7. Perbaikan Bug "Apply Job" di Mobile

- **Masalah:** Pada aplikasi mobile, saat muncul dialog *Cover Letter*, jika pengguna menekan tombol *Back* (kembali) atau menutup dialog, sistem justru tetap mengirimkan lamaran pekerjaan secara otomatis (skip & apply).
- **Solusi:** Memperbarui `job_detail_controller.dart`. Logika saat dialog ditutup kini ditangani dengan benar sebagai aksi "Batal" (Cancel), dan ditambahkan juga tombol "Cancel" eksplisit pada antarmuka.

8. Konsolidasi UI Banner di Halaman Profil

- **Masalah:** Terdapat duplikasi *banner* (Doublean) yang muncul di halaman profil pekerja pada aplikasi mobile.
- **Solusi:** Menghapus *banner* redundan di `worker_profile_page.dart` dan menyatukan logika tampilannya ke dalam *primary banner* tunggal agar UI terlihat bersih dan profesional.

Kesimpulan

Sistem kini lebih kokoh menahan serangan siber, logika pelamaran kerja menjadi lebih sesuai dengan aturan bisnis (memblokir status *not sure*), dan bug krusial pada pengalaman *user* (Mobile) telah teratasi. Semua perubahan telah dilakukan *Commit* dan *Push* ke repositori.